

GDPR Compliance Audit Report

Automated security and privacy compliance scan

inavate.co.uk

43
/ 100

HIGH RISK

Overall Compliance Score

REPORT GENERATED

31 May 2026

TOTAL ISSUES FOUND

9

EXECUTIVE SUMMARY



HIGH RISK

This report presents the results of an automated security and GDPR compliance scan of **inavate.co.uk**, conducted on Sunday, 31 May 2026 at 16:46. Seven independent checks were performed covering HTTPS security, HTTP security headers, email authentication, open port exposure, subdomain enumeration, technology disclosure, and GDPR compliance requirements. Results reflect the publicly observable state of the website at the time of scan.

7 CHECKS RUN	1 PASSED	3 WARNINGS	2 FAILED	1 ERRORS
--------------------	-------------	---------------	-------------	-------------

KEY FINDINGS

Issues are classified as Critical (failed checks requiring immediate action) or Advisory (warnings to address within 30 days).

🚫 CRITICAL ISSUES — Address Immediately (within 7 days)

HTTP Security Headers

🚫 CRITICAL FAIL

WHAT FAILED

- Missing header: Strict-Transport-Security (HSTS) (critical)
- Missing header: X-Frame-Options
- Missing header: X-Content-Type-Options
- Missing header: Referrer-Policy

BUSINESS IMPACT

No browser security protections — customer data and your reputation are at risk.

REAL-WORLD EXAMPLE — E-commerce site, ~50,000 registered customers, 2022

What happened: Missing CSP and HSTS. Attacker injected a payment skimmer script into checkout pages.

Result: 400 customers' credit card details stolen. Mandatory ICO breach report filed.

Cost: £15,000 remediation + £8,000 legal fees + ongoing ICO investigation

🕒 **Timeline: Fix within 7 days**

Open Port Scan

🚫 CRITICAL FAIL

WHAT FAILED

- Port 3306 (MySQL) is open — should not be public

BUSINESS IMPACT

Database or admin ports are publicly accessible — this is a critical breach risk.

REAL-WORLD EXAMPLE — WordPress hosting reseller, 2022

What happened: MySQL port 3306 publicly accessible. Automated scanner accessed it within 4 hours of launch.

Result: 5,000 customer records stolen. Mandatory ICO data breach notification filed.

Cost: £4,000 remediation + ICO notification costs + reputation damage

🕒 **Timeline: Fix within 7 days**

⚠️ ADVISORY ISSUES — Plan to Address (within 30 days)

SSL / TLS Certificate Analysis

⚠ ADVISORY WARNING

WHAT WAS FOUND

- Certificate expires in 37 days — upcoming renewal needed

Your certificate is approaching expiry — visitors will soon see security warnings.

REAL-WORLD EXAMPLE — SaaS platform, 100 active users, 2023

What happened: SSL certificate expired over a weekend. Auto-renewal had silently failed months earlier.

Cost: £3,000 in lost revenue + emergency developer call-out

 **Timeline:** Plan to address within 30 days

Technology Detection

⚠ ADVISORY WARNING

WHAT WAS FOUND

- WordPress detected — ensure plugins are up to date
- Server technology disclosed via X-Powered-By: PHP/8.2.30

Technology disclosures give attackers a detailed roadmap of your system.

REAL-WORLD EXAMPLE — Restaurant chain, 3 locations, 2024

What happened: PHP and server version disclosed in response headers. Known CVE targeted within 24 hours.

Cost: £3,500 remediation + 6 hours downtime + emergency redeployment

 **Timeline:** Plan to address within 30 days

GDPR Compliance

⚠ ADVISORY WARNING

WHAT WAS FOUND

- No data subject rights information detected

Incomplete GDPR compliance — regulatory risk is building.

REAL-WORLD EXAMPLE — Marketing agency, 12 staff, 2023

What happened: Facebook Pixel and Google Analytics firing without a compliant consent mechanism.

Cost: £12,000 ICO fine + £3,000 to implement compliant consent management

 **Timeline:** Plan to address within 30 days

DETAILED SCAN RESULTS

Each of the seven scanners is documented below with its status, specific findings, business impact, a real-world SME example, and step-by-step remediation guidance.

SSL / TLS Certificate Analysis

⚠️ WARNING

Checks: Certificate validity, expiry date, TLS version (1.2+), cipher strength.

STATUS & FINDINGS

- Certificate expires in 37 days — upcoming renewal needed

WHAT THIS MEANS

Your HTTPS certificate is valid but requires attention soon — it may be approaching expiry or using an older configuration. Visitors can still connect securely for now.

WHAT COULD HAPPEN IF NOT FIXED

Your certificate is approaching expiry — visitors will soon see security warnings.

- Browsers display a 'Not Secure' warning when the certificate expires, driving visitors away immediately
- Google may lower your search ranking in response to certificate issues
- Payment and login data could become unencrypted if expiry is not addressed
- GDPR requires adequate technical security — an expired certificate is a violation under Article 32

Responsible:

Your web host or web developer.

REAL-WORLD EXAMPLE — SIMILAR BUSINESS

Business:

SaaS platform, 100 active users, 2023

What happened:

SSL certificate expired over a weekend. Auto-renewal had silently failed months earlier.

Result:

Site inaccessible for 8 hours on a Monday morning. Customers unable to log in.

Cost / Fine:

£3,000 in lost revenue + emergency developer call-out

Lesson:

Certificate monitoring and auto-renewal are critical — expiry is always preventable.

HOW TO FIX THIS

1. Log in to your hosting control panel and locate certificate management

2. Check the expiry date and enable auto-renewal if available

3. Use Let's Encrypt via your host (cPanel, Plesk, Cloudflare all support free auto-renewing certificates)

4. Verify TLS 1.2 and 1.3 are enabled and TLS 1.0/1.1 are disabled in your server config

5. Test your result at <https://www.ssllabs.com/ssltest/>

Time:

30 minutes

Cost:

Free (Let's Encrypt) to £100/year (paid cert)

Who:

Web host or web developer

Urgency:

Within 30 days

HTTP Security Headers

❌ FAIL

Checks: CSP, HSTS, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy.

STATUS & FINDINGS

- Missing header: Strict-Transport-Security (HSTS) (critical)
- Missing header: X-Frame-Options
- Missing header: X-Content-Type-Options
- Missing header: Referrer-Policy

WHAT THIS MEANS

Critical security headers are absent. Visitors' browsers have no guidance to protect against common attacks — leaving your site exposed to script injection, clickjacking, and unencrypted connections.

WHAT COULD HAPPEN IF NOT FIXED

No browser security protections — customer data and your reputation are at risk.

- Attackers can inject malicious scripts (XSS) to steal credit card numbers and personal data
- Your site can be embedded in a hidden iframe to trick users into submitting credentials (clickjacking)
- Google Safe Browsing may blacklist your domain — you disappear from search results
- Customers whose data is stolen can sue under GDPR for failing to implement basic security measures
- GDPR fine: up to £17.5 million for inadequate technical security
- Recovering from a hacked site typically costs £1,000–£10,000+

Responsible: Your web host or web designer.

REAL-WORLD EXAMPLE — SIMILAR BUSINESS

Business: E-commerce site, ~50,000 registered customers, 2022
What happened: Missing CSP and HSTS. Attacker injected a payment skimmer script into checkout pages.
Result: 400 customers' credit card details stolen. Mandatory ICO breach report filed.
Cost / Fine: **£15,000 remediation + £8,000 legal fees + ongoing ICO investigation**
Lesson: *CSP and HSTS together prevent the most common client-side attacks. Both are free to add.*

HOW TO FIX THIS

1. Treat this as urgent — contact your web host or developer today
2. Priority headers to add first: Content-Security-Policy and Strict-Transport-Security (HSTS)
3. Then add: X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy
4. Each header is a single configuration line — no application code changes needed
5. Verify at <https://securityheaders.com> until you achieve an A rating

Time: 30–60 minutes **Cost:** Free — server configuration only

Who: Web host or developer with server access **Urgency:** **Immediately — within 7 days maximum**

DNS Records — Email Authentication

✓ PASS

Checks: SPF, DKIM, and DMARC TXT records for email spoofing prevention.

STATUS & FINDINGS

✓ No issues found for this check.

WHAT THIS MEANS

Email authentication (SPF, DKIM, DMARC) is correctly configured. Emails from your domain are verified, protecting your brand from spoofing and improving deliverability.

Open Port Scan

Checks: Ports 80, 443, 22 (SSH), 3306 (MySQL), 5432 (PostgreSQL), 8080, 3000, 27017 (MongoDB).

✗
FAIL

STATUS & FINDINGS

- Port 3306 (MySQL) is open — should not be public

WHAT THIS MEANS

Dangerous ports are publicly accessible. Database servers or admin services can be directly reached from the internet — without going through your web application's security.

WHAT COULD HAPPEN IF NOT FIXED

Database or admin ports are publicly accessible — this is a critical breach risk.

- Automated bots attempt to brute-force SSH (port 22) continuously, 24 hours a day
- A single weak password gives an attacker complete access to your server and all data
- Direct database access bypasses all web application security controls
- Ransomware operators specifically target exposed databases to encrypt data and demand payment
- GDPR mandatory breach notification to ICO within 72 hours — fines up to £17.5 million
- Average ransomware demand for UK SMEs: £50,000–£500,000

Responsible: Your web host or server administrator.

REAL-WORLD EXAMPLE — SIMILAR BUSINESS

Business: WordPress hosting reseller, 2022
What happened: MySQL port 3306 publicly accessible. Automated scanner accessed it within 4 hours of launch.
Result: 5,000 customer records stolen. Mandatory ICO data breach notification filed.
Cost / Fine: **£4,000 remediation + ICO notification costs + reputation damage**
Lesson: *Database ports must never be publicly accessible. No exceptions.*

HOW TO FIX THIS

1. Log in to your cloud provider or hosting control panel today
2. Close all database ports from public access: 3306 (MySQL), 5432 (PostgreSQL), 27017 (MongoDB)
3. Restrict SSH (port 22) to your specific IP address — not 0.0.0.0/0
4. Close development server ports (3000, 8080) unless specifically required
5. Access databases via SSH tunnel or private VPN instead of direct public connection

Time: 15–30 minutes **Cost:** Free — firewall configuration. VPN: £5–15/month if needed

Who: Web host or server administrator

Urgency: **Immediately — automated bots are scanning these ports right now**

Subdomain Enumeration

? ERROR

Checks: Public certificate transparency logs (crt.sh) — passive, no active probing.

STATUS & FINDINGS

Error: Request failed with status code 502

✓ No issues found for this check.

WHAT THIS MEANS

Subdomain lookup via certificate transparency logs failed. This is usually a temporary crt.sh outage — try again later.

Technology Detection

⚠
WARNING

Checks: CMS, frameworks, server software, and version disclosures in headers and source.

STATUS & FINDINGS

- WordPress detected — ensure plugins are up to date
- Server technology disclosed via X-Powered-By: PHP/8.2.30

WHAT THIS MEANS

Server or software version information is being disclosed in HTTP headers or page source. This acts as a roadmap for automated attack tools.

WHAT COULD HAPPEN IF NOT FIXED

Technology disclosures give attackers a detailed roadmap of your system.

- Knowing your exact server or CMS version lets attackers search for known exploits immediately
- Automated vulnerability scanners target disclosed versions within hours of indexing
- Outdated CMS plugins are the top cause of SME website compromises
- A hacked site costs £1,000–£10,000+ to clean and restore — plus downtime and SEO damage

Responsible: Your web host or web developer.

REAL-WORLD EXAMPLE — SIMILAR BUSINESS

Business: Restaurant chain, 3 locations, 2024
What happened: PHP and server version disclosed in response headers. Known CVE targeted within 24 hours.
Result: Admin panel compromised via known PHP vulnerability. Reservation data exfiltrated.
Cost / Fine: **£3,500 remediation + 6 hours downtime + emergency redeployment**
Lesson: *Hiding version information removes your site from automated exploit target lists.*

HOW TO FIX THIS

1. Ask your host or developer to suppress server version headers (X-Powered-By, Server)
2. For Nginx: `server_tokens off;` | For Apache: `ServerTokens Prod + ServerSignature Off` | PHP: `expose_php = Off`
3. Update all CMS plugins to their latest versions from the admin dashboard
4. Set up automatic plugin updates for security releases

Time: 30–60 minutes **Cost:** Free **Who:** Web host or web developer **Urgency:** Within 14 days

GDPR Compliance

⚠ WARNING

Checks: Privacy policy, cookie consent banner, tracking scripts, data subject rights.

STATUS & FINDINGS

- No data subject rights information detected

WHAT THIS MEANS

Some GDPR compliance requirements are missing or incomplete. The gaps identified represent legal risk under UK and EU data protection law.

WHAT COULD HAPPEN IF NOT FIXED

Incomplete GDPR compliance — regulatory risk is building.

- ICO can investigate based on a single complaint from any website visitor
- Missing cookie consent means you are processing data without a legal basis
- Privacy advocates and competitors can file regulatory complaints against your business
- Without consent records, you cannot demonstrate compliance if investigated
- Fines for incomplete compliance range from £4,000 to £500,000 depending on severity

Responsible: You are legally responsible as the data controller — this cannot be delegated.

REAL-WORLD EXAMPLE — SIMILAR BUSINESS

Business: Marketing agency, 12 staff, 2023
What happened: Facebook Pixel and Google Analytics firing without a compliant consent mechanism.
Result: ICO investigation following a single customer complaint. Consent deemed non-compliant.
Cost / Fine: **£12,000 ICO fine + £3,000 to implement compliant consent management**
Lesson: *Running tracking scripts without a lawful consent basis is an active, ongoing GDPR violation.*

HOW TO FIX THIS

1. Implement a cookie consent management platform (Cookiebot, CookieYes, or Usercentrics)
2. Ensure the consent banner blocks all tracking until the visitor actively accepts
3. Add a footer link to your privacy policy on every page
4. Update your privacy policy to include: data collected, purpose, legal basis, retention periods, and data subject rights
5. Add a clear data subject rights contact method (email or online form)

Time: 2–4 hours **Cost:** Free consent tools available. Paid: £10–50/month

Who: Web developer (implementation) + business owner (policy content) **Urgency:** Within 30 days

RECOMMENDATIONS — ACTION PLAN

Issues ordered by priority. Addresses the question: "What do we fix first, how long will it take, and who does it?"

Priority 1 (Critical) — Fix within 7 days

1. HTTP Security Headers

Estimated effort: 30–60 minutes

Who: Web host or developer with server access

2. Open Port Scan

Estimated effort: 15–30 minutes

Who: Web host or server administrator

Priority 2 (Advisory) — Fix within 30 days

1. SSL / TLS Certificate Analysis

Estimated effort: 30 minutes

Who: Web host or web developer

2. Technology Detection

Estimated effort: 30–60 minutes

Who: Web host or web developer

3. GDPR Compliance

Estimated effort: 2–4 hours

Who: Web developer (implementation) + business owner (policy content)

Priority 3 — Ongoing best practice

1. Set up SSL certificate monitoring and auto-renewal alerts

2. Schedule a quarterly security re-scan to track improvements

3. Keep all CMS plugins, themes, and frameworks updated monthly

4. Review DNS records every time a service is decommissioned

5. Conduct an annual full security and GDPR compliance review

GDPR & SECURITY COMPLIANCE CHECKLIST

A quick-reference summary of the key compliance requirements assessed in this scan.

✓ HTTPS enabled (SSL/TLS certificate present and active)

✗ SSL certificate valid and not expired or expiring soon

✗ Critical security headers configured (CSP and HSTS)

✗ All recommended security headers configured

✓ Email authentication configured (SPF / DKIM / DMARC)

✗ No dangerous ports exposed to the internet

✓ Privacy policy present and linked on website

✓ Cookie consent mechanism implemented

✓ No tracking scripts running without user consent

✗ Data subject rights information present

5/10 requirements passing (50%)

RISK ASSESSMENT SUMMARY

Issue count by severity level and overall risk classification.

2 Critical issues (failed checks)

3 Warnings (advisory issues)

1 Passed checks

1 Checks with errors (could not complete)

OVERALL RISK LEVEL

CRITICAL

REMEDIATION TIMELINE

A suggested timeline for addressing all identified issues.

IMMEDIATE ACTION REQUIRED (0–7 DAYS)

- ☐ HTTP Security Headers
- ☐ Open Port Scan

Estimated effort: See detailed results section

SHORT-TERM (8–30 DAYS)

- ☐ SSL / TLS Certificate Analysis
- ☐ Technology Detection
- ☐ GDPR Compliance

Estimated effort: See detailed results section

ONGOING (RECOMMENDED BEST PRACTICE)

- Set up SSL certificate monitoring and auto-renewal
- Schedule quarterly security audit (use SecureVault or similar tool)
- Monthly: update CMS plugins, themes, and dependencies
- Annually: review and update privacy policy and cookie consent

NEXT STEPS

Recommended actions after reviewing this report.

1. Review this report with your web designer, web host, or IT team
2. Share the priority list — red items must be fixed within 7 days

3. Request a specific timeline and written confirmation for each fix
4. Implement fixes starting with Critical (red) items first
5. Schedule a follow-up scan in 30 days to verify all fixes are in place
6. Set up SSL certificate monitoring to prevent unexpected expiry
7. Contact SecureVault if you need help interpreting or acting on any findings

Disclaimer: This report was generated by SecureVault automated scanning tools and is provided for informational purposes only. It does not constitute legal advice and does not guarantee GDPR compliance or freedom from regulatory action. Results reflect the publicly observable state of the website at the time of scan and may not capture all security vulnerabilities or compliance issues. Some findings may require professional interpretation. Always consult a qualified security professional or legal advisor for comprehensive compliance guidance. Rescan recommended every 90 days for active monitoring.

Generated: 31 May 2026 | Report ID: SV-MPTYCCW4 | Valid for 30 days from scan date.